

Blog com autenticação

OFICINA • NÍVEL 4 — BACK-END • PYTHON + FASTAPI + SQLITE + JWT • 8H ESTIMADAS • PRÉ-REQUISITO: MÓDULO 10

O primeiro sistema com usuários de verdade. Cadastro, login e — a parte que quase todo mundo erra — garantir que ninguém edite o post do vizinho.

O QUE VOCÊ APRENDE AQUI

- Hash de senha
- Sessão ou token
- Autorização por dono do recurso
- Erros que não entregam informação

ARQUIVOS DA PASTA

- main.py
- auth.py
- modelos.py
- banco.py
- test_auth.py
- .env.example

ETAPAS • MARQUE CONFORME ENTREGA

- Cadastro**

POST /usuarios com email e senha. Guarde o hash com bcrypt ou argon2, nunca a senha. Recuse email repetido.
- Login**

Compare o hash e devolva um token com expiração curta. Senha errada e email inexistente respondem **a mesma coisa** — veja as armadilhas.
- Rota protegida**

Uma dependência que lê o token, valida a assinatura e devolve o usuário. Token ausente ou inválido: 401.
- CRUD de posts**

Criar, listar, ver, editar e apagar. O autor sai do token, nunca do corpo da requisição.
- Autorização**

Editar e apagar só o que é seu. Esta é a etapa mais importante do projeto — é o IDOR da Aula 10.7.
- Testar o que importa**

Escreva o teste que tenta editar o post de outro usuário e **espera falhar**. Teste de segurança é teste que confirma a recusa.

ARMADILHAS CONHECIDAS • LEIA ANTES DE TRAVAR

- Responder "usuário não encontrado" e "senha incorreta" separadamente entrega a lista de quem tem conta no seu sistema — é enumeração de usuários. Uma resposta só: "credenciais inválidas".
- Aceitar autor_id do corpo permite publicar em nome de qualquer um. O autor vem do token, sempre.

| Devolver 403 ao editar post alheio confirma que aquele post existe. 404 não conta nada — Aula 10.7.

| JWT é assinado, não criptografado: qualquer um lê o conteúdo. Nada sensível dentro dele.

CRITÉRIOS DE ACEITAÇÃO

- ☐ A senha nunca aparece em texto no banco nem em log algum
 - ☐ Usuário A recebe 404 ao tentar editar o post de B
 - ☐ Email inexistente e senha errada dão exatamente a mesma resposta
 - ☐ Token expirado devolve 401 com mensagem clara
 - ☐ O campo autor_id enviado no corpo é ignorado
 - ☐ Existe teste automatizado que prova a recusa da edição alheia
-

Faltam 6 critérios.

TERMINOU? DESAFIOS EXTRAS

Caminho da Programação · Oficina of-blog-auth · 20 oficinas no total
<https://lucasmedeiroscds.github.io/caminho-programacao/>